Security Requirements Document

Web-Based ML Model Evaluator | v1.1 (Corrected)

1. Introduction

1.1 Purpose

This document defines security requirements for the Web-Based ML Model Evaluator. It complements the SRS and Test Plan by identifying the protections required for accounts, uploaded datasets, model runs, evaluation results, and downloadable artifacts.

1.2 System Context

The system is a browser-accessible application that accepts user-uploaded tabular datasets, performs preprocessing and machine-learning training/evaluation, stores run metadata and results, and permits users to review or download supported outputs. The system serves three human actor roles — **Student**, **Instructor**, and **Admin** — and one internal actor, the **ML Service**. The security scope therefore focuses on authentication, role-based server-side authorization, user-level data isolation, safe file handling, input validation, artifact integrity, error handling, and deployment practices.

1.3 Related Documents and Traceability

Document	Purpose in the project
Software Requirements Specification (SRS), v1.1	Defines the functional requirements FR-1.1 through FR-7.5 and non-functional requirements NFR-1 through NFR-14 referenced below. v1.1 adds FR-7.5 (role-based access control) and the Actors section.
Test Plan Document, v1.1	Defines test procedures. Security cases use SEC requirement IDs and include linked SRS requirement IDs. v1.1 adds FR-7.3 and FR-7.4 test cases.
GitHub Project backlog	Implementation work is tracked through project issues and sprint assignments; security requirements should be added to the backlog where applicable.

1.4 Requirement Status

“Stated” means the SRS already requires the behaviour at a high level. “Proposed” means this document adds security detail that the team should review and accept, modify, or reject before treating it as a release commitment. Requirements labelled as a mix distinguish the existing high-level requirement from the added implementation detail.

2. Assets and Threats

Asset	Security concern
User accounts and credentials	Account takeover and unauthorized access.
Uploaded datasets	Confidentiality, malicious/malformed files, and unintended cross-user disclosure.
Preprocessing configuration and target selection	Invalid configuration, unintended data processing, or misuse of another user's dataset.
Model runs, metrics, and evaluation visualizations	Integrity, correct ownership, and prevention of cross-user access.
Model artifacts and reports	Unauthorized downloads, wrong-run artifacts, and exposure of sensitive information contained in datasets.
Application configuration and secrets	Credential/API-key exposure and insecure deployment.
Run history and logs	Accountability without leaking passwords, tokens, or dataset contents.
Role and access control system ★	Privilege escalation, role spoofing, and unauthorized access to Admin or Instructor functions by lower-privileged users. ★ Added in v1.1.

3. Security Requirements

Authentication

ID	Requirement	SRS Trace	Basis
SEC-AUTH-1	All dataset, model-run, history, and download operations shall require an authenticated user. Anonymous access shall be limited to public entry points such as login and registration.	FR-1.2; FR-1.4	Stated

Credential Storage

ID	Requirement	SRS Trace	Basis
SEC-AUTH-2	Passwords shall never be stored in plaintext. The application shall use a suitable salted password-hashing mechanism and shall not log or return passwords.	NFR-3	Stated at high level; hashing detail proposed

Login Feedback

ID	Requirement	SRS Trace	Basis
SEC-AUTH-3	Failed login attempts shall return a generic error that does not disclose whether an account exists.	FR-1.2; NFR-13	Proposed

Abuse Prevention

ID	Requirement	SRS Trace	Basis
SEC-AUTH-4	The application shall apply a configurable rate limit or equivalent protection to repeated failed logins and sensitive API requests. This requirement is confirmed as in-scope; the team shall define and document the threshold values before release.	NFR-3; NFR-11	Proposed — in scope ★

Session Security

ID	Requirement	SRS Trace	Basis
SEC-SES-1	Session identifiers or authentication tokens shall be generated securely, validated server-side, and protected from unnecessary exposure.	FR-1.2; NFR-3	Proposed

Session Expiry

ID	Requirement	SRS Trace	Basis
SEC-SES-2	Sessions shall expire according to a documented idle and/or maximum lifetime policy; expired sessions shall require re-authentication.	FR-1.3; NFR-3	Proposed

Logout

ID	Requirement	SRS Trace	Basis
SEC-SES-3	Logout shall invalidate the active session or token so it cannot be reused to access protected resources.	FR-1.3	Stated

Authorization

ID	Requirement	SRS Trace	Basis
SEC-AZ-1	The backend shall authorize every protected request; frontend-only hiding of controls shall not be considered sufficient protection.	FR-1.4; NFR-4	Stated

User Resource Ownership

ID	Requirement	SRS Trace	Basis
SEC-AZ-2	A user shall only access datasets, run records, metrics, and artifacts they own, unless an explicit sharing feature is implemented.	FR-2.5; FR-6.1; NFR-5	Stated

Data Confidentiality

ID	Requirement	SRS Trace	Basis
SEC-DAT-1	Uploaded datasets, run configurations, metrics, and artifacts shall not be exposed to other users through listing endpoints, direct identifiers, or download URLs.	FR-2.5; FR-6.1; NFR-5	Stated

Upload Safety

ID	Requirement	SRS Trace	Basis
SEC-DAT-2	The backend shall enforce configured file-type and size limits, validate file content, and reject malformed or unsupported uploads before processing.	FR-2.1; FR-2.2; NFR-11	Stated at high level; content/size validation proposed

Run Integrity

ID	Requirement	SRS Trace	Basis
SEC-DAT-3	A failed upload, preprocessing step, training run, or export shall not corrupt previously completed runs or unrelated user data.	FR-4.3; FR-6.1; NFR-6; NFR-12	Stated

Artifact Integrity

ID	Requirement	SRS Trace	Basis
SEC-DAT-4	Each downloadable model artifact or report shall be associated with the correct user and run, and shall not be substituted with another run's artifact.	FR-5.4; FR-6.1; NFR-12	Stated

Server-side Validation

ID	Requirement	SRS Trace	Basis
SEC-INP-1	The backend shall validate all user-controlled inputs, including dataset identifiers, target columns, preprocessing options, split values, algorithm selections, and export requests.	FR-2.2; FR-3.1; FR-3.2; FR-3.3; FR-4.1; FR-5.4; NFR-13	Stated

Injection Resistance

ID	Requirement	SRS Trace	Basis
SEC-INP-2	Database access shall use parameterized queries or safe ORM operations; user-provided search/filter and metadata values shall not be executable as database commands.	NFR-10; NFR-13	Proposed

Output Safety

ID	Requirement	SRS Trace	Basis
SEC-INP-3	User-controlled text and error details shall be rendered safely; responses shall not expose stack traces, secret values, filesystem paths, or internal configuration.	NFR-13	Stated at high level; output-encoding detail proposed

Secret Management

ID	Requirement	SRS Trace	Basis
SEC-OPS-1	Passwords, API keys, and other secrets shall not be committed to source control or exposed in frontend bundles, logs, or API responses.	NFR-3; NFR-13; NFR-14	Proposed

Dependency Hygiene

ID	Requirement	SRS Trace	Basis
SEC-OPS-2	The project shall declare its dependencies and provide a process for reviewing and updating vulnerable dependencies.	NFR-10; NFR-14	Proposed

Backup and Recovery

ID	Requirement	SRS Trace	Basis
SEC-OPS-3	If persistent datasets, run history, or artifacts are stored, the project shall document how they are backed up and restored for the target deployment.	NFR-6; NFR-14	Proposed

Auditability

ID	Requirement	SRS Trace	Basis
SEC-OPS-4	Security-relevant events such as failed authentication, denied resource access, and failed sensitive operations should be logged without recording passwords, tokens, or dataset contents.	FR-6.3; NFR-13	Proposed

Transport Security

ID	Requirement	SRS Trace	Basis
SEC-OPS-5	Deployed environments handling user credentials or uploaded data shall use HTTPS/TLS; development-only local HTTP use shall be documented as such.	NFR-3; NFR-14	Proposed

4. Security Verification and Traceability

The companion Test Plan contains security-focused cases using IDs in the form SEC-<GROUP>-<NUMBER>-<TYPE>-<SEQUENCE>. Each case links to the relevant SEC requirement and one or more SRS requirements. A requirement is not considered verified until the test has been executed and its actual result and status recorded.

5. Suggested Security Test Coverage

SEC ID	Linked SRS IDs	Test Case ID	Verification intent
SEC-AUTH-1	FR-1.4	SEC-AUTH-1-ST-1	Request a protected dataset/run endpoint without a session; access is denied.
SEC-AUTH-2	NFR-3	SEC-AUTH-2-ST-1	Register a test account and verify the stored password representation is a salted hash and does not equal the submitted plaintext.
SEC-AUTH-3	FR-1.2; NFR-13	SEC-AUTH-3-ST-1	Attempt login with an unknown user and with a wrong password; messages do not reveal account existence.
SEC-AUTH-4	NFR-3; NFR-11	SEC-AUTH-4-NFT-1	Repeat failed login or sensitive requests; rate limiting/throttling activates according to the configured policy.
SEC-SES-1	FR-1.2; NFR-3	SEC-SES-1-ST-1	Inspect session/token handling and ensure credentials/tokens are not exposed in logs or URLs.
SEC-SES-2	FR-1.3; NFR-3	SEC-SES-2-ST-1	Allow a session to expire; protected action requires re-authentication.
SEC-SES-3	FR-1.3	SEC-SES-3-ST-1	Log out and replay the old session/token; protected access is denied.
SEC-AZ-1	FR-1.4; NFR-4	SEC-AZ-1-ST-1	Call a protected API directly as an unauthorized user; backend denies access.

SEC ID	Linked SRS IDs	Test Case ID	Verification intent
SEC-AZ-2	FR-2.5; FR-6.1; NFR-5	SEC-AZ-2-ST-1	User A requests User B's dataset/run by identifier; access is denied without leaking resource details.
SEC-DAT-1	NFR-5	SEC-DAT-1-ST-1	Check dataset lists, run history, direct IDs, and downloads for cross-user leakage.
SEC-DAT-2	FR-2.1; FR-2.2; NFR-11	SEC-DAT-2-IT-1	Upload malformed, unsupported, and over-limit files; unsafe inputs are rejected.
SEC-DAT-3	FR-4.3; FR-6.1; NFR-6; NFR-12	SEC-DAT-3-IT-1	Trigger a failed run after a completed run; the earlier run remains unchanged.
SEC-DAT-4	FR-5.4; NFR-12	SEC-DAT-4-IT-1	Request an artifact for a selected run; returned artifact belongs to that user and run.
SEC-INP-1	FR-2.2; FR-3.1–3.3; FR-4.1; FR-5.4	SEC-INP-1-UT-1	Submit invalid target, split, algorithm, preprocessing, or export values directly to the backend; each is rejected.
SEC-INP-2	NFR-10; NFR-13	SEC-INP-2-REV-1	Review database access paths and test injection-like inputs; inputs are treated as data.
SEC-INP-3	NFR-13	SEC-INP-3-ST-1	Submit script-like text and trigger controlled errors; output is safely rendered and internal details are hidden.
SEC-OPS-1	NFR-3; NFR-13; NFR-14	SEC-OPS-1-REV-1	Inspect repository and frontend build for committed secrets or exposed credentials.
SEC-OPS-2	NFR-10; NFR-14	SEC-OPS-2-REV-1	Verify dependencies are declared and review the available dependency vulnerability-check process.
SEC-OPS-3	NFR-6; NFR-14	SEC-OPS-3-REV-1	Review backup/restore instructions for persistent datasets, run metadata, and artifacts.
SEC-OPS-4	FR-6.3; NFR-13	SEC-OPS-4-IT-1	Trigger failed login/denied access and verify security events are logged without secrets or dataset contents.
SEC-OPS-5	NFR-3; NFR-14	SEC-OPS-5-NFT-1	Verify deployed credential/data traffic uses HTTPS/TLS; document local development exceptions.

6. Open Decisions and Assumptions

- **Rate limiting (SEC-AUTH-4) is confirmed as in-scope.** The team shall define and document threshold values (e.g., maximum failed attempts per minute, lockout duration) before release testing.
- The team must document session/token expiry behaviour based on the authentication approach actually implemented.
- The maximum upload size, accepted CSV encoding/structure, and supported file validation rules must be agreed and documented.
- The application's deployment model determines the exact HTTPS, secrets, backup, and dependency-scanning arrangements.
- The system should not claim that model artifacts are encrypted at rest or that audit logs are immutable unless those controls are implemented and tested.
- These security requirements do not imply that all proposed controls are already implemented; the test plan records evidence after execution.

7. Acceptance and Change Control

The team should review proposed requirements, assign implementation issues, and update the SRS and Test Plan if a security decision changes functional behaviour. IDs should remain stable after use in the GitHub backlog or test evidence; if a requirement is removed, mark it as retired rather than reusing its ID.

8. Administrative and Instructor Access Controls

These controls align the security requirements with the actors in the UML and Use Case Flows. Admin is the only role permitted to manage accounts or access administrative system logs. Instructor access is read-only and limited to evaluation results explicitly made available for review. **The role-based access control system required by FR-7.5 is the foundation for all controls in this section; without it, the requirements below cannot be enforced.**

ID	Requirement	SRS Trace	Basis
SEC-AZ-3	Only an authenticated Admin shall access user-management functions. Regular users and Instructors shall be denied access through both the UI and direct API requests.	FR-7.1; FR-7.5 ★	Derived from UC-12
SEC-AZ-4	Only an authenticated Admin shall access administrative dataset-management functions. Such operations shall preserve dataset ownership and associations with model runs.	FR-7.2; FR-7.5 ★; FR-2.5; NFR-12	Derived from UC-13
SEC-AUD-1	System activity logs shall be read-only through the application and shall not expose passwords, session tokens, API keys, or raw dataset contents.	FR-7.3; NFR-13	Derived from UC-14
SEC-AZ-5	Instructor access shall be read-only and limited to evaluation results explicitly made available for review. Instructors shall not manage users, alter datasets, start training, or modify stored results unless separately authorized.	FR-7.4; FR-7.5 ★; FR-5.1; FR-5.2	Derived from UML and UC-09

★ *FR-7.5 trace added in v1.1 — role enforcement depends on the user role field being implemented.*

8.1 Verification Mapping

Security ID	Test Plan case(s)	Verification intent
SEC-AZ-3	FR-7.1-ST-2; FR-7.1-ST-3	Admin user-management permission and non-admin denial.
SEC-AZ-4	FR-7.2-ST-1; FR-7.2-ST-2; FR-7.2-ST-3	Admin dataset management, data association integrity, and non-admin denial.
SEC-AUD-1	FR-7.3-ST-1; FR-7.3-ST-2	Relevant activity logging, read-only behaviour, and sensitive-data exclusion.
SEC-AZ-5	FR-7.4-ST-1; FR-7.4-ST-2; FR-7.4-ST-3	Instructor read-only result access and enforcement of scope.

8.2 Administrative Log Access

SEC-AZ-6 — Only an authenticated Admin shall be able to view the administrative system-log interface and its underlying endpoints. Other users, including Instructors, shall be denied access even when they call the endpoint directly. SRS trace: FR-7.3; FR-7.5. Basis: derived from UC-14 and the actor boundary in the UML.

8.3 Verification Mapping Update

SEC-AZ-6 is verified by FR-7.3-ST-3. SEC-AUD-1 is verified by FR-7.3-ST-1 and FR-7.3-ST-2. SEC-AZ-3 is verified by FR-7.1-ST-2 and FR-7.1-ST-3; SEC-AZ-4 by FR-7.2-ST-1 through FR-7.2-ST-3; SEC-AZ-5 by FR-7.4-ST-1 through FR-7.4-ST-3.